面向 AI 生成内容的密码水印与可验证溯源系统设计实现：v2 扩展报告

v2 从 v1 的单文件登记流程扩展为独立的多媒体凭证、密钥生命周期、Merkle 批量证明、SM3 审计链、攻击矩阵和 Web 演示层。v1 的 `ProvenanceService`、发布 gate、SM3/SM2、Manifest、SQLite 和 PDF 栅格化路径保留；v2 使用 `v2.sqlite`、`key_manager.sqlite`、`batch_proof.sqlite` 和 `audit.sqlite`，默认不修改 v1 数据库。

总体架构与安全边界

`content_registry` 由 `V2Store` 保存内容、最终字节摘要、Manifest、签名和版本父链；`manifest_v2` 固定字段顺序、NFC、JCS、字段名长度前缀、SM3 摘要和 SM2-SM3-DER 签名；`watermark_service/media_adapters` 统一图片、PDF、WAV 和可选编解码器；`key_manager` 保存 key_id、算法、有效期、状态、前序 key_id 和公钥指纹，私钥只保留受保护路径元数据；`batch_proof` 用固定排序的 Manifest hash 建 Merkle Tree；`audit_service` 用 SM3 哈希链和 checkpoint 记录登记、验证、密钥和批量事件；`attack_lab` 输出 JSON/CSV 攻击矩阵；`v2_api` 和 `v2.html` 提供离线演示。

水印是传播后的 ContentID 识别线索，不能替代密码证据。最终决策还需要最终字节 SM3、确定性 Manifest、SM2 签名、密钥状态、版本链和撤销状态。系统不证明内容真实、合法、无偏见，也不把水印单独当作法律上的作者身份证明。

系统边界可以概括为：`content_registry -> manifest_service -> watermark_service/media_adapters -> key_manager -> batch_proof/audit_service -> API/CLI/dashboard`。登记时先生成 ContentID，再在最终媒体字节上执行水印恢复 gate，之后计算 SM3、规范化 Manifest 和 SM2 签名；验证时分别显示水印线索、字节摘要、Manifest、签名、Merkle proof、版本链和撤销状态，最后才形成决策。水印恢复成功不等于签名成功，任一密码证据失败都不能报告为可信发布。

数据模型包含 `v2_contents`、`v2_batches`、`publisher_keys`、`audit_events` 和 checkpoint 表。内容记录保存媒体类型、原始/最终摘要、ContentID、Manifest、父版本和发布状态；批量记录保存固定排序叶子、Merkle root、树高、发布者签名和 key_id；密钥记录只保存公钥及生命周期元数据，私钥不进入提交包。

交付目录中的 `figures/v2/architecture.svg` 和 `figures/v2/verification-flow.svg` 分别对应总体架构和验证决策流程；它们是无外部依赖的静态图，可在普通浏览器中查看。

密钥生命周期

`gm-provenance-v2 keygen` 生成并登记公钥元数据；`key-rotate` 记录 predecessor_key_id；旧 Manifest 使用历史公钥继续验签，新内容使用新 key_id；`key-revoke` 更新撤销状态。被吊销或过期密钥的历史签名仍可验证密码正确性，但 v2 决策标为 `RISK_REVOKED_KEY`，不报告为当前可信发布。

Manifest 与批量证明

Manifest v2 的 canonical bytes 以协议域、固定字段数、字段名长度、字段值长度和 JCS 值组成。字段包括 `content_id`、`key_id`、`media_type`、`content_hash`、`metadata_hash`、父版本和允许变换集合。批量凭证按 Manifest hash UTF-8 字典序构造树，保存 `batch_id`、root、叶子数量、树高和签名；单项 proof 只需 root、leaf 和带方向 sibling 列表。叶子替换、root 篡改、batch_id 错配和跨批复用都会失败。

多媒体与攻击实验室

图片复用 watermark-v1 和最终编码 gate；PDF 使用 PDFium 120 DPI
页级渲染并保留页面编号、页级摘要和页面删除/重排攻击；WAV 使用离线 PCM16 LSB
标识，覆盖重采样、音量、转码和片段截取；MP3、FLAC、MP4 在没有系统编解码器时显式返回
`UNAVAILABLE`，不会伪造成功。攻击矩阵记录 attack_id、媒体、类型、参数、输入、预期、实际决策、恢复
ID、摘要/签名状态和耗时。

审计与演示

每条审计事件包含 event_id、event_type、ContentID、actor、UTC timestamp、result、previous_event_hash
和 event_hash；每 10 条生成 checkpoint，支持首个坏节点、断链、删除、字段修改、时间倒退和重复 event_id
定位。运行 `scripts/run_v2_demo.py` 可离线生成十个图片凭证、一个 Merkle root、攻击
JSON/CSV、审计导出和性能 CSV；运行 `uvicorn gm_provenance.v2_api:app`
后可在浏览器查看登记、验证、密钥状态和审计结果。

固定演示现在包含 10 个可复现 PNG 样本，批量创建 10 叶 Merkle root，并对首个样本运行 10
类图片攻击。`scripts/run_v2_pdf_demo.py` 使用 `sample_data/real_pdf_page1.pdf`，固定 120
DPI、RGB、1020×1320 页面尺寸生成 `page-001-rendered.png` 与 `page-001-final.png`，日志同时记录原始
PDF、渲染页、最终编码页、恢复出的 ContentID 和最终摘要。

目标与实测

v2 将识别率、拒绝率、误报率、平均/P50/P95 延迟、批量吞吐量和存储开销作为独立实验字段输出。当前 smoke
实测为：登记 3 样本平均/P50/P95 `959.838/953.121/996.161 ms`，验证 `744.351/746.589/784.466
ms`，批量创建 3 叶 `295.336 ms`；这是小样本实测，不是 1000 行压力指标。v1 的中心 95% 裁剪 S0 `48/80` 与
P95 `1237.624 ms` 仍是已知限制，不能写成达到 95% 或 100 ms 目标。Round9 的 1000 次尝试为 gate
`992/1000`，在已发布的 992 个样本上 D0 `992/992`、G0 `0/992`；这三个数字不是 v2 smoke
的总体成功率。已知覆盖缺口包括 AI 图片 `0/20`、外部真实 PDF `0/10`、完整 1000
样本压力运行，以及需要系统编解码器的 MP3/FLAC/MP4。

对比

方案	来源线索	完整性/来源证据	版本/撤销	批量/审计
单独签名	无	有	有限	无
单独水印	有	无	无	无
签名+水印	有	有	有限	无
v2 签名+水印+版本链+Merkle+审计链	有	有	有	有